GUÍA DE ESTUDIO

Protocolos de Red Seguros: VPNs, IPsec y SSL/TLS

UNIDAD	SESIÓN	TIPO	NIVEL
2	5	ESTUDIO	AVANZADO

CUGDL - Universidad de Guadalajara
Arquitectura de Sistemas de Seguridad
Licenciatura en Ciberseguridad

Autor: Carlos Pulido Rosas
Abril 2026

OBJETIVOS DE APRENDIZAJE

- Explicar qué es una VPN, qué problema resuelve y en qué escenarios es la solución correcta.
- Distinguir cómo funcionan IPsec y SSL/TLS como protocolos de tunelización y comparar sus casos de uso.
- Identificar los modos de operación de IPsec (transporte y túnel) y qué protege cada uno.
- Conectar el tráfico VPN con el punto ciego del IDS/IPS visto en la sesión anterior y entender las implicaciones de arquitectura.

CONTEXTO

En la sesión anterior vimos que el IDS no puede inspeccionar tráfico cifrado — el payload de una conexión HTTPS o VPN es una caja negra para cualquier sensor de red. Esta sesión explica qué hay dentro de esa caja: los protocolos que hacen posible el cifrado de comunicaciones en redes inseguras.

VPNs, IPsec y SSL/TLS son la infraestructura invisible que protege cada transacción bancaria, cada conexión remota al trabajo y cada API call entre microservicios. Entender cómo funcionan es fundamental para diseñar arquitecturas donde la seguridad no dependa únicamente del perímetro.

1. VPN — Virtual Private Network

Una VPN crea un canal cifrado entre dos puntos a través de una red no confiable — generalmente Internet. El término 'virtual' es clave: no es un cable físico dedicado sino un túnel lógico que encapsula y cifra el tráfico antes de enviarlo por la red pública. Desde la perspectiva del usuario, es como si estuviera conectado directamente a la red destino sin importar dónde esté físicamente.

ANALOGÍA — Data Engineering: túnel VPN como canal seguro de ingestión

Sin VPN es como enviar datos de producción a tu Data Lake por HTTP sin cifrar — cualquier nodo intermedio puede leer o modificar los datos en tránsito.

Con VPN es como usar un canal de streaming cifrado end-to-end: los datos viajan empaquetados en un contenedor cifrado que solo el origen y el destino pueden abrir. Los routers intermedios solo ven 'hay tráfico', no 'qué tráfico'.

El protocolo VPN es el formato del contenedor. IPsec y SSL/TLS son dos estándares distintos de ese formato, cada uno optimizado para un caso de uso diferente.

1.1 Tipos de VPN por arquitectura

Hay tres arquitecturas principales de VPN que resuelven problemas distintos. Entender cuál aplica a cada escenario es más importante que memorizar los protocolos.

Tipo	Quién conecta	Protocolo típico	Caso de uso
Site-to-Site	Red A ↔ Red B (ambas fijas)	IPsec	Conectar sede central con sucursal o datacenter
Remote Access	Usuario remoto ↔ Red corporativa	SSL/TLS (OpenVPN, AnyConnect)	Empleado trabajando desde casa
Client-to-Client	Dos dispositivos individuales	WireGuard, IPsec	Comunicación directa entre dos hosts específicos

2. IPsec — Internet Protocol Security

IPsec es un conjunto de protocolos que opera en la Capa 3 del modelo OSI — la capa de red. Esto significa que cifra y autentica cada paquete IP individualmente, completamente transparente para las aplicaciones que corren encima. Una aplicación no necesita saber nada sobre IPsec para beneficiarse de su protección.

IPsec no es un protocolo único sino una suite compuesta por tres componentes que trabajan juntos: AH para autenticación, ESP para cifrado, e IKE para el intercambio de claves.

2.1 Componentes de IPsec

Los tres protocolos que componen IPsec

- AH (Authentication Header) — autentica el paquete completo garantizando que no fue modificado en tránsito. No cifra el contenido, solo verifica la integridad. Rara vez se usa solo porque no provee confidencialidad.
- ESP (Encapsulating Security Payload) — cifra el payload del paquete y opcionalmente lo autentica. Es el componente más usado de IPsec porque provee tanto confidencialidad como integridad.
- IKE (Internet Key Exchange) — negocia y establece las claves de cifrado entre los dos extremos del túnel antes de que empiece la comunicación real. IKEv2 es la versión actual, más rápida y estable que IKEv1.

2.2 Modos de operación: transporte vs. túnel

IPsec tiene dos modos de operación que determinan qué parte del paquete se cifra. La elección entre ellos depende de si los extremos del túnel son los mismos hosts que generan el tráfico o si son gateways que protegen a otros hosts detrás de ellos.

Modo	Qué se cifra	Cabecera IP original	Cuándo usarlo
Transporte	Solo el payload (datos)	Se mantiene visible	Comunicación directa entre dos hosts que conocen IPsec
Túnel	El paquete IP completo (cabecera + datos)	Se reemplaza por una nueva cabecera	VPN site-to-site entre dos gateways que protegen redes internas

ANALOGÍA — Modo transporte vs. modo túnel

Modo transporte: envías una carta con el contenido cifrado pero el sobre muestra claramente el remitente y destinatario reales. Cualquiera que intercepte el sobre sabe quién le escribe a quién, aunque no pueda leer la carta.

Modo túnel: metes el sobre original dentro de otro sobre con una dirección diferente. Quien intercepta solo ve la dirección del sobre exterior (la del gateway), no la dirección real del remitente ni del destinatario original. Confidencialidad completa del origen y destino real.

2.3 Fases de negociación IKE

Antes de que fluya cualquier dato cifrado, los dos extremos del túnel IPsec deben acordar qué algoritmos usar y generar las claves compartidas. Este proceso ocurre en dos fases.

Fase 1 y Fase 2 de IKE

- Fase 1 — ISAKMP SA: los dos gateways se autentican mutuamente (mediante certificados o clave precompartida) y establecen un canal seguro para negociar los parámetros. El resultado es un Security Association (SA) de control.
- Fase 2 — IPsec SA: usando el canal seguro de Fase 1, negocian los parámetros específicos del túnel de datos: algoritmo de cifrado (AES-256, 3DES), algoritmo de hash (SHA-256), tiempo de vida de las claves y modo (transporte o túnel).
- Una vez completadas ambas fases, el túnel está activo y el tráfico fluye cifrado. Las claves se rotan automáticamente según el tiempo de vida configurado — típicamente cada 8 horas para el tráfico y cada 24 horas para el canal de control.

3. SSL/TLS — Secure Sockets Layer / Transport Layer Security

SSL/TLS opera en la Capa 4-5 del modelo OSI — entre la capa de transporte y la capa de aplicación. A diferencia de IPsec que cifra paquetes IP, SSL/TLS cifra sesiones de aplicación. Cada vez que tu navegador muestra el candado en la barra de direcciones, está usando TLS.

SSL es el protocolo original, ya obsoleto y con múltiples vulnerabilidades conocidas (SSLv2, SSLv3). TLS es su sucesor — TLS 1.2 fue el estándar dominante durante años y TLS 1.3 (publicado en 2018) es la versión actual con mejoras significativas de seguridad y rendimiento.

3.1 El handshake TLS

Antes de que fluya cualquier dato cifrado, el cliente y el servidor ejecutan el handshake TLS — una negociación inicial que establece los parámetros del canal cifrado. En TLS 1.3 este proceso es significativamente más rápido que en versiones anteriores.

Pasos del handshake TLS 1.3

- 1. ClientHello — el cliente envía las versiones TLS que soporta, los cipher suites disponibles y un número aleatorio.
- 2. ServerHello — el servidor elige la versión y el cipher suite, presenta su certificado digital y envía su clave pública.
- 3. Verificación del certificado — el cliente verifica que el certificado fue emitido por una CA (Certificate Authority) confiable y que corresponde al dominio correcto.
- 4. Generación de claves — ambas partes usan el algoritmo de intercambio de claves (Diffie-Hellman en TLS 1.3) para generar una clave de sesión compartida sin transmitirla por la red.
- 5. Finished — ambas partes confirman que el handshake fue exitoso y comienza la transmisión de datos cifrados con la clave de sesión.

3.2 Certificados digitales y PKI

Un certificado digital es el 'pasaporte' de un servidor. Contiene su clave pública, el nombre del dominio al que pertenece, la fecha de expiración y la firma de una Certificate Authority (CA) que garantiza su autenticidad. La infraestructura que gestiona estos certificados se llama PKI (Public Key Infrastructure).

Componentes clave de PKI

- CA (Certificate Authority) — entidad confiable que emite y firma certificados. Las CAs raíz (DigiCert, Let's Encrypt, Comodo) vienen preinstaladas en los sistemas operativos y navegadores.
- Certificado X.509 — formato estándar del certificado. Contiene: dominio (CN), organización, CA emisora, clave pública, fechas de validez y firma digital de la CA.
- Cadena de confianza — un certificado de servidor es firmado por una CA intermedia que a su vez es firmada por una CA raíz. El navegador verifica cada eslabón de la cadena.
- Let's Encrypt — CA gratuita y automatizada que emite certificados de 90 días. Democratizó HTTPS al eliminar el costo de los certificados.

3.3 TLS como protocolo VPN: SSL VPN

Además de proteger conexiones HTTPS, TLS se usa como protocolo de tunelización para VPNs de acceso remoto. Las SSL VPNs tienen una ventaja crítica sobre IPsec en escenarios de acceso remoto: funcionan sobre el puerto 443 (HTTPS), que prácticamente nunca está bloqueado en redes públicas, hoteles, aeropuertos o redes corporativas restrictivas.

Criterio	IPsec VPN	SSL VPN
Capa OSI	Capa 3 — red	Capa 4-5 — transporte/sesión
Puerto	UDP 500, UDP 4500, protocolo 50/51	TCP/UDP 443
Firewalls restrictivos	Frecuentemente bloqueado	Raramente bloqueado (mismo que HTTPS)
Configuracion cliente	Requiere software/config en el OS	Puede funcionar solo con navegador
Rendimiento	Alto — opera en capa de red	Ligeramente menor — overhead adicional
Caso ideal	Site-to-site entre sedes fijas	Acceso remoto de empleados
Ejemplo comercial	Cisco ASA, Palo Alto GlobalProtect	Cisco AnyConnect, OpenVPN, WireGuard

4. VPN, cifrado y el punto ciego del IDS

Esta sección conecta directamente con lo que viste en la Sesión 6. El IDS/IPS no puede inspeccionar el contenido de tráfico cifrado — y ahora sabes exactamente por qué. El payload de una conexión IPsec ESP o de una sesión TLS está cifrado con claves de sesión que solo conocen los dos extremos del túnel. El sensor de red ve paquetes, pero no puede descifrarlos sin esas claves.

Esto crea un dilema de arquitectura real que enfrentan los equipos de seguridad: cuanto más cifrado hay en la red, más visibilidad pierde el IDS. Los atacantes lo saben — y es por eso que las herramientas modernas de C2 (Command and Control) usan HTTPS o tunelización sobre TLS para exfiltrar datos y recibir instrucciones sin ser detectadas.

Tres estrategias para recuperar visibilidad en tráfico cifrado

- SSL/TLS Inspection (man-in-the-middle autorizado) — el NGFW o un proxy descifra el tráfico, lo inspecciona y lo re-cifra antes de enviarlo al destino. Efectivo pero con implicaciones de privacidad y rendimiento.
- Análisis de metadatos (NetFlow/IPFIX) — aunque no puede ver el contenido, el IDS puede analizar patrones: volumen de datos, frecuencia de conexiones, duración de sesiones, IPs de destino. Un servidor interno que de repente envía 10 GB a una IP desconocida es sospechoso aunque el contenido esté cifrado.
- Inspección en el endpoint (EDR/HIDS) — el agente HIDS analiza el tráfico después de que el sistema operativo lo descifra, lo que significa que ve el contenido real independientemente del cifrado de red. Esta es una de las razones por las que Wazuh, que usarán hoy en el laboratorio, es tan valioso.

ANALOGÍA — El dilema del cifrado en Data Engineering

Es como tener un pipeline de datos donde todos los mensajes van cifrados end-to-end. Tu sistema de calidad de datos puede ver que hay tráfico, puede ver el tamaño de los mensajes y la frecuencia, pero no puede validar el schema ni detectar datos corruptos dentro del mensaje.

La solución no es eliminar el cifrado — es mover la inspección al punto donde los datos están descifrados: el consumer del pipeline, equivalente al agente HIDS en el host.

CASO REAL: Operación VPNFilter — malware en routers VPN (2018)

En 2018, el FBI y Cisco Talos descubrieron VPNFilter, un malware que infectó más de 500,000 routers domésticos y de pequeñas empresas en 54 países. El malware tenía capacidad de interceptar tráfico antes de que se cifrara, inyectar contenido malicioso en conexiones HTTP y destruir el firmware del dispositivo de forma remota.

Lo que hacía particularmente peligroso a VPNFilter era su módulo 'ssler': se posicionaba como un proxy entre el dispositivo del usuario y el router, forzando degradación de HTTPS a HTTP (ataque SSL stripping) para leer el tráfico en texto plano antes de que se cifrara con TLS. En efecto, resolvía el problema del punto ciego del cifrado desde el lado del atacante.

Conexión con esta guía: el ataque explotó la capa donde el tráfico aún no está cifrado — el dispositivo del usuario antes del handshake TLS. Ningún NGFW ni IDS de red habría detectado la interceptación porque ocurría antes de que el tráfico saliera del dispositivo comprometido. Solo un HIDS en el dispositivo afectado o un análisis de comportamiento de red (tráfico HTTP donde debería haber HTTPS) habría generado una alerta.

PREGUNTAS DE REFLEXIÓN

1. Un empleado trabaja desde un café con WiFi público y se conecta a la red corporativa mediante SSL VPN. ¿Qué amenazas específicas mitiga la VPN en este escenario y qué amenazas no mitiga? Considera que el café podría tener un punto de acceso WiFi falso (evil twin attack).
1. Tu empresa tiene una VPN site-to-site IPsec entre la sede central y una sucursal. El equipo de seguridad propone implementar SSL Inspection en el NGFW para recuperar visibilidad sobre el tráfico cifrado interno. ¿Qué argumentos técnicos y organizacionales considerarías para decidir si implementarla o no?
2. WireGuard es un protocolo VPN moderno que usa criptografía más simple y moderna que IPsec, con solo 4,000 líneas de código vs. las 400,000 de IPsec. Algunos arquitectos argumentan que menos código significa menos superficie de ataque. ¿Estás de acuerdo con ese argumento? ¿Qué otros factores considerarías antes de reemplazar IPsec con WireGuard en una infraestructura empresarial?

RECURSOS

- [Docs] RFC 7296 — Internet Key Exchange Protocol Version 2 (IKEv2) — https://tools.ietf.org/html/rfc7296 (gratuito)
- [Docs] RFC 8446 — The Transport Layer Security (TLS) Protocol Version 1.3 — https://tools.ietf.org/html/rfc8446 (gratuito)
- [Docs] OpenVPN — documentacion oficial — https://openvpn.net/community-resources/ (gratuito)
- [Docs] WireGuard — protocolo VPN moderno — https://www.wireguard.com/papers/wireguard.pdf (gratuito)
- [Video] NetworkChuck — 'VPNs explained' — https://youtube.com/@NetworkChuck (~15 min)
- [Video] Hussein Nasser — 'TLS Handshake explained' — https://youtube.com/@hnasr (~20 min)
- [TryHackMe] Room: 'Protocols and Servers 2' — https://tryhackme.com/room/protocolsandservers2 — cubre TLS y VPN en practica